

Anonymous Credentials in Practice:

A Study of Device Binding, Zero-Knowledge Proofs, and the Road to Standardisation

Author: Federico Rufini

Supervisor: Prof. Visconti

Academic Year 2025/2026

Anonymous credential systems promise to let users prove attributes about themselves—age, nationality, professional qualifications—without revealing their identity or allowing different presentations to be linked. This report documents the work carried out during my Excellence Path, which consisted of a focused study of the recent scientific literature on privacy-preserving credentials, with particular attention to two influential lines of research: anonymous credentials built on top of the ECDSA signature scheme as found in deployed secure hardware (Frigo and Shelat, 2024), and device-bound anonymous credentials designed to remain private even under partial or total hardware compromise (Friedrichs et al., 2025). The study is framed by the imminent rollout of the EU Digital Identity (EUDI) Wallet, which turns these formerly academic questions into a matter of practical urgency.

1. Motivation

Anonymous credentials are one of the oldest studied objects in applied cryptography, yet their deployment in real systems has remained elusive for decades. The core tension is well known: to be trustworthy, a credential must be tied to a device that cannot be cloned; but the same binding that prevents cloning also enables tracking. Breaking this tension without modifying existing hardware or relying on non-standard cryptographic assumptions is the central open problem of the field.

Under the guidance of Prof. Visconti, I used my Excellence Path to study this problem through its primary literature. The goal was not a broad survey but a deep reading of a small number of foundational and recent papers, sufficient to understand their technical contributions, to evaluate them critically, and to locate the open problems they leave behind. The choice of papers was guided by a combination of cryptographic depth and practical relevance: both works studied are directly applicable to systems being standardised and deployed today.

2. Background: the hardware constraint

An anonymous credential system allows an *issuer* to sign a set of attributes, and a *holder* to later prove possession of a valid signature—and statements about the signed attributes—to a *verifier*, without revealing the signature itself or allowing the verifier to link two presentations. The classical construction by Camenisch and Lysyanskaya achieves this through algebraic signatures over which efficient zero-knowledge proofs of knowledge can be built. More recently, **BBS signatures**—now standardised by the IETF—have emerged as the preferred instantiation: they support multi-message signing, selective disclosure, and efficient ZK proof protocols built on pairings.

Device binding adds a further requirement: the credential must be cryptographically tied to a specific device so that it cannot be trivially copied. The natural mechanism is to keep a secret key inside a *Secure Element* (SE), a tamper-resistant chip that performs cryptographic operations without ever exporting the key. The problem is that today's Secure Elements—those found in hundreds of millions of shipped smartphones—support only **ECDSA over NIST P-256**. They cannot natively compute BBS or BLS signatures, pairing operations, or zero-knowledge proofs. Any scheme requiring the hardware to do more therefore cannot be deployed without a new generation of devices. This constraint is the common starting point of both papers studied, and the main reason the problem remains open.

3. Longfellow: anonymous credentials from ECDSA (Frigo and Shelat, 2024)

3.1 Contribution

The paper asks a deceptively simple question: can one build a fully-featured anonymous credential system using *only* ECDSA, the primitive that existing secure hardware already supports? The construction—called **Longfellow**—answers yes, and is the most technically demanding work studied during the path.

The key insight is that the Secure Element does not need to compute a privacy-preserving signature. Instead, it signs a commitment using its standard ECDSA key, and the holder produces a *zero-knowledge proof* establishing that (a) there exists a valid ECDSA signature over the commitment, (b) the commitment opens to a credential issued by a trusted issuer, and (c) the credential contains the claimed attribute values. The verifier learns nothing beyond the truth of these statements. Because nothing about the ECDSA key or the credential is revealed, multiple presentations are unlinkable.

3.2 Proof system architecture

The ZK proof system is a carefully engineered combination of components. **Ligero** (MPC-in-the-head) serves as the core proof system: it requires no trusted setup, relies only on collision-resistant hash functions (making it post-quantum secure in isolation), and supports arbitrary arithmetic circuits. To avoid the bottleneck of heavy number-theoretic transforms, Ligero is integrated with a **sum-check** protocol, which allows the verifier to check polynomial sums over boolean hypercubes without NTT operations. Polynomial commitments are instantiated via **Reed-Solomon codes**, using additive FFT over binary fields and linear convolution over NIST P-256.

The most original technical contribution is the treatment of two sub-computations that naturally live in different fields. ECDSA verification works over a prime field; SHA-256 hashing works over a binary field ($\text{GF}(2^{128})$). The paper introduces two separate optimised circuits, one for each field, connected by a **MAC-based cross-field consistency check**: the witness shared between the circuits is authenticated so that a cheating prover cannot substitute inconsistent values across the field boundary. The resulting proof is made non-interactive via the **Fiat-Shamir** heuristic, producing a single message that any verifier can check without further interaction—a hard requirement of OpenID4VP and ISO 18013-5. The European fork *Longfellow-zk* (Dyne.org) subsequently added SIMD128 assembler optimisations targeting European credential formats.

3.3 Performance

The reported figures are remarkable for a general ZK system: ECDSA proofs in approximately 60 ms, and a full ISO MDOC presentation proof in roughly 1.2 seconds on mobile hardware depending on credential size. The work demonstrates convincingly that ZK-based, hardware-compatible anonymous credentials are no longer purely theoretical.

3.4 Critical assessment

Several limitations emerged from the study. First, the post-quantum picture is mixed: Ligero's security rests only on hash functions and is post-quantum safe, but the ECDSA signature from the Secure Element is broken by Shor's algorithm. The scheme is therefore best understood as a transitional solution, viable until Secure Elements migrate to post-quantum primitives. Second, the SE remains a *single point of failure*: a compromised SE key collapses user privacy entirely, and the paper proposes no multi-party technique to distribute this trust. Third, the codebase exceeds 20 000 lines of code and the authors have already issued corrections for implementation errors—a reminder that the gap between a sound proof system and a secure implementation is not trivial to close.

4. Device-Bound Anonymous Credentials With(out) Trusted Hardware

Friedrichs, Lehmann, Sidorenko, and Zacharakis, 2025

4.1 Contribution

This paper approaches device binding from a different direction. Rather than optimising for compatibility with existing ECDSA hardware, it asks: what privacy guarantees are achievable when the hardware itself cannot be fully trusted? The motivation is grounded in two concrete scenarios already present in the EUDI ecosystem:

- Many smartphones lack a locally certified SE at the required Level of Assurance (LoA High), so the regulation foresees the use of *Remote HSMs*—cloud-based security modules outside the user’s physical control.
- Even local Secure Elements are “black boxes”: subverted firmware could embed a subliminal channel that leaks the user’s identity across presentations without any party being able to detect it.

The paper’s first contribution is a formal hierarchy of four unlinkability levels (Unlink-0 through Unlink-3) capturing progressively stronger adversarial models, up to a SE that is fully under real-time adversary control. This taxonomy is itself a contribution: it gives the field a precise vocabulary for what “device binding without trusted hardware” actually means, something prior work had left informal.

4.2 Three constructions

All three proposed schemes use **BBS signatures** for the credential itself and differ only in how the device contributes its binding signature:

1. **BBS-Schnorr**. Device binding via a Schnorr signature. Efficient, but achieves only Unlink-1: a malicious SE can exploit the signature randomness to embed a subliminal channel.
2. **BBS-BLS**. Replaces Schnorr with a deterministic BLS signature. Determinism eliminates subliminal channels (Unlink-2), but the SE still learns the message it signs, so presentation context leaks to the hardware.
3. **BBS-BlindBLS**. The SE signs blindly, learning neither the message nor the presentation context. Achieves Unlink-3 and full *SE-obliviousness*; the construction designed for Remote HSMs.

4.3 Critical assessment

The work resolves two main weaknesses of Longfellow: it removes the SE single point of failure by supporting remote hardware, and it replaces the ECDSA circuit with BBS, enabling richer ZK proofs without hardware-specific engineering. Limitations are of two kinds. Some are declared by the authors: BBS-Schnorr is not subversion-resilient, and BBS-BLS is not SE-oblivious; these are acknowledged trade-offs, not oversights. More fundamentally, *none of the three constructions is post-quantum secure*—BBS, BLS, and Schnorr all rest on the hardness of discrete logarithm.

Two further limitations emerged from independent analysis. The Remote HSM model introduces unavoidable *metadata leakage through timing*: an adversary observing network traffic can correlate HSM request timing with user activity even without breaking any cryptographic primitive, a channel the paper does not address. And permanent network connectivity is required, making the scheme unsuitable for offline credential presentation—a real requirement in practice, which the scheme can only partially mitigate by pre-fetching non-revocation proofs when connectivity is available.

5. Comparison and synthesis

Reading the two papers together reveals a clear complementarity. Longfellow optimises for compatibility with today’s deployed hardware at the cost of a complex, ECDSA-specific proof system. DBAC optimises for a richer privacy model—including hardware subversion and Remote

HSM scenarios—at the cost of requiring devices that can compute BBS or BLS. Neither achieves post-quantum security end-to-end, and neither fully resolves the tension between hardware binding and user privacy under a fully malicious device.

A third dimension became visible during the study. The recent announcement that **Android 17** will expose **ML-DSA** (the NIST lattice-based signature standard) through the standard Android Keystore TEE interface opens, for the first time, the prospect of a post-quantum primitive natively available in mobile secure hardware. ZK proof systems for lattice-based signatures are still substantially heavier than their elliptic-curve counterparts, so the problem is not immediately solved—but the landscape is shifting. The DBAC unlinkability hierarchy provides a ready-made formal framework for evaluating new constructions that will emerge in this setting.

6. Relevance to the EU Digital Identity Wallet

The EU Digital Identity Wallet—currently in its pre-deployment phase, governed by the Architecture and Reference Framework (ARF)—is the largest digital identity infrastructure project ever attempted in Europe, and the closest real-world instantiation of the problems studied in this literature. Its selective-disclosure mechanism relies on salted-hash SD-JWT Verifiable Credentials and ISO/IEC 18013-5 mDOC presentations: mechanisms that inherit the granularity and linkability limitations the anonymous-credential literature has documented for decades. Disclosing a full date-of-birth field to prove “I am over 18”, or allowing multiple presentations to be correlated through device-bound attribute signatures, are not hypothetical issues but design choices embedded in the current standard.

The ARF itself acknowledges that zero-knowledge proofs are the only viable long-term mitigation, yet mandates none. Longfellow has attracted serious attention as a near-term upgrade path precisely because it requires no hardware changes; the Dyne.org fork targets European credential formats specifically. DBAC directly addresses the regulation’s provision for Remote HSMs, providing a formal treatment of the privacy implications the regulatory text leaves underspecified. The literature studied during this path is therefore not only academically relevant—it is a close reading of the cryptographic infrastructure that will shape European digital identity for the foreseeable future.

7. Outcome of the path

The Excellence Path produced a detailed, critical understanding of two of the most technically substantive recent contributions to device-bound anonymous credentials. Beyond the content, the work developed two capacities harder to acquire from coursework alone: reading a complex cryptographic paper and identifying not only what it claims but what it implicitly assumes or leaves open; and situating a research contribution within a moving practical context—hardware announcements, standardisation timelines, regulatory choices—that determines which open problems are actually worth pursuing. I am grateful to Prof. Visconti for the direction and the critical engagement that shaped this study.

References

- [1] M. Frigo, a. shelat, *Anonymous Credentials from ECDSA* (Longfellow), Google, 2024.
- [2] J. Friedrichs, A. Lehmann, A. Sidorenko, A. Zacharakis, *Device-Bound Anonymous Credentials With(out) Trusted Hardware*, 2025.
- [3] D. Boneh, X. Boyen, H. Shacham, *Short Group Signatures* (BBS); IETF draft-irtf-cfrg-bbs-signatures.
- [4] S. Ames, C. Hazay, Y. Ishai, M. Venkatasubramanian, *Ligero: Lightweight Sublinear Arguments Without a Trusted Setup*, CCS 2017.
- [5] A. Lehmann, A. Sidorenko, A. Zacharakis, *Vision: A Modular Framework for Anonymous Credential Systems*.
- [6] European Commission, *Architecture and Reference Framework (ARF) for the EUDI Wallet*, eudi.dev.
- [7] OpenID Foundation, *OpenID for Verifiable Presentations (OpenID4VP)*; ISO/IEC 18013-5:2021, *Mobile driving licence*

(mDL) application.

[8] Google Security Blog, *Post-Quantum Cryptography in Android* (ML-DSA, Android 17), 2026.